

DET-010 | Privileged Azure AD Role Assignment

ID: DET-010

MITRE ID: T1078.004

Data Source: AuditLogs

Severity: High

Tactic: Persistence

Category: PRIVILEGE ESCALATION

ADX MAPPING LOGIC:

Mapping: mv-expand is practiced by expanding a dynamic column. We use parse_json() and mv-expand on StormEvents to simulate expanding nested JSON role-assignment records — the exact operator used with AuditLogs TargetResources.

OBJECTIVE: Practice mv-expand and parse_json() — critical operators for AuditLogs. Real Sentinel: AuditLogs | mv-expand TargetResources to extract role name and target user from the nested JSON array.

KQL QUERY (RUNNABLE ON ADX FREE TIER)

```
let PrivilegedRoles = dynamic([
"Tornado","Hurricane","Blizzard"]); // = Global Admin, Security Admin
StormEvents
| where StartTime > ago(365d)
| extend RoleDetails = todynamic(strcat(
'{"role":""," EventType,
","assignedTo":""," State,
","initiatedBy":""," Source, ""}')
| mv-expand RoleDetails // core operator for AuditLogs
| extend
RoleName = tostring(RoleDetails.role),
AssignedTo = tostring(RoleDetails.assignedTo),
InitiatedBy = tostring(RoleDetails.initiatedBy)
| where RoleName in (PrivilegedRoles)
| summarize
TotalAssignments = count(),
UniqueRoles = dcount(RoleName),
RoleList = make_set(RoleName, 5),
AssignedUsers = make_set(AssignedTo, 5)
by InitiatedBy, bin(StartTime, 1h)
| project StartTime, InitiatedBy, TotalAssignments, UniqueRoles, RoleList, AssignedUsers
| order by TotalAssignments desc | take 20
```

INVESTIGATION STEPS

1. Confirm the role assignment was authorised via change management.
2. Check if the InitiatedBy account shows signs of compromise.
3. Review what actions the newly privileged user performed.
4. Verify if a PIM workflow was followed.

RESPONSE ACTIONS

- Remove the role assignment if unauthorised.
- Review all actions taken by the newly privileged account.
- Force MFA re-authentication for both accounts.
- Enable PIM for all privileged role assignments going forward.

Output from Above KQL Query:

```
1 let KnownGoodProcesses = dynamic([
2   "Rain","Fog","Mist","Drizzle"]);
3 let SuspiciousEventTypes = dynamic(["Tornado","Waterspout","Dust Devil","Funnel Cloud","Blizzard"]);
4 StormEvents
5 | where StartTime > ago(365d)
6 | where EventType !in~ (KnownGoodProcesses) // exclude known-good (whitelist)
7 | where EventType in (SuspiciousEventTypes) // only suspicious processes
8 | extend RiskLabel = case(
9   EventType == "Tornado", "CRITICAL - Mimikatz Pattern",
10  EventType == "Waterspout", "CRITICAL - Procdump Pattern",
11  EventType == "Blizzard", "HIGH - Unknown Dumper",
12  "HIGH - Suspicious Access"
13 )
14 | summarize
15 AccessCount = count(),
16 SourceList = make_set(Source, 5),
17 FirstSeen = min(StartTime),
18 LastSeen = max(StartTime)
19 by EventType, State, RiskLabel
20 | project DeviceName = State, AttackProcess = EventType, RiskLabel,
21 AccessCount, SourceList, FirstSeen, LastSeen
22 | order by AccessCount desc | take 20
```

DeviceName	AttackProcess	RiskLabel	AccessCount	SourceList	FirstSeen	LastSeen
No Rows To Show						

KQL Detection Query in Sentinel:

AuditLogs

| where TimeGenerated > ago(1h)

| where OperationName == "Add member to role"

| mv-expand TargetResources

| extend

TargetUser = tostring(TargetResources.userPrincipalName),

RoleName = tostring(TargetResources.displayName)

| where RoleName in ("Global Administrator","Security Administrator","Exchange Administrator","SharePoint Administrator","Privileged Role Administrator",

"User Administrator",

"Billing Administrator"

)

| extend InitiatedBy = tostring(InitiatedBy.user.userPrincipalName)

| project

TimeGenerated, TargetUser, RoleName,

InitiatedBy, CorrelationId

| order by TimeGenerated desc